



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Naxclow IoT Platform

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-16
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | Naxclow IoT Platform - Vulnerability Report

Published: 2026-06-16 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

Naxclow IoT Platform

1. Executive Summary

CISA ICS Advisory ICSA-26-162-02 discloses seven vulnerabilities affecting the Naxclow IoT Platform used by Smart Doorbell X3, X Smart Home, V720, and ix cam products. The advisory describes a platform-level security failure pattern rather than a single isolated bug: weak ownership validation, missing authorization, hard-coded cryptographic material, predictable device identifiers, non-rotating relay credentials, and sensitive WiFi material exposed through production hardware debug access.

Successful exploitation could allow an attacker to impersonate devices, intercept or manipulate communications, harvest credentials, enumerate active device fleets, or gain unauthorized access. The highest-risk issue is CVE-2026-28742, a CVSS v3.1 9.8 hard-coded cryptographic key weakness that can allow forged platform requests once the platform-wide signing salt is recovered. Several companion issues make that primitive more operationally useful by enabling device takeover, credential retrieval, persistent relay access, and fleet enumeration.

Naxclow did not respond to CISA's coordination attempts. No known public exploitation specifically targeting these vulnerabilities had been reported to CISA at advisory release time. Lost Boys Cyber assesses the remediation picture as constrained: there is no vendor-confirmed patch path in the CISA advisory, so exposed organizations should treat affected devices as untrusted until the vendor provides corrected firmware/platform behavior or the devices are removed from sensitive environments.

Priority	Defender Decision	Lost Boys Cyber Assessment
1	Identify Naxclow-dependent devices and accounts	Immediate action; affected product versions are listed as all versions for four product lines
2	Remove or isolate devices from sensitive networks	High priority where devices bridge residential, commercial, OT-adjacent, or executive environments
3	Rotate WiFi credentials where physical access to devices may have occurred	Required because CVE-2026-50099 exposes SSID/PSK/key material over UART
4	Monitor for anomalous device/account binding, relay activity, and fleet enumeration	Useful detective layer; vendor/platform telemetry may be limited
5	Demand vendor remediation or plan replacement	Strategic control because CISA lists no vendor-supplied fix

2. Intelligence Requirement

This report answers the following intelligence requirement: What is the risk posed by the Naxclow IoT Platform vulnerability cluster disclosed in CISA ICSA-26-162-02, which environments are exposed, what confidence should defenders place in the available evidence, and what actions should be taken while no vendor-confirmed remediation is available?

Requirement	Answer
Primary stakeholders	Security operations, vulnerability management, physical security, facilities, OT/IoT asset owners, executive risk owners
Decision supported	Device isolation, replacement planning, credential rotation, and monitoring for compromised IoT device identity

Time horizon	Immediate exposure triage within 24-72 hours; replacement or compensating-control plan within 14-30 days
Key uncertainty	Public source detail is concentrated in the CISA advisory/CSAF record; vendor remediation status is unknown because Naxclow did not coordinate with CISA
Confidence	High for affected products, vulnerability descriptions, CVSS scores, and CISA mitigation guidance; medium for exploit maturity outside CISA's statement of no known public exploitation

Assumption: because CISA lists the affected versions as `vers:all/\*`, this report treats all known deployments of the named Naxclow product families as exposed until an organization receives vendor-confirmed corrected firmware, service-side remediation, or replacement hardware.

3. Source Review and Confidence

The source base is sufficient for defensive prioritization because the primary source is a final CISA ICS advisory with CSAF data. The advisory provides vulnerability descriptions, CVSS vectors, affected products, CWE mappings, sector/deployment context, reporter acknowledgment, and CISA's recommended defensive practices. Lost Boys Cyber did not identify a vendor advisory or patch notice during this review, and CISA explicitly states Naxclow did not respond to coordination attempts.

Source	Key Contribution	Reliability	Confidence Notes
CISA ICSA-26-162-02	Canonical advisory for affected products, vulnerability descriptions, CVSS scores, and mitigation guidance	High	CISA ICS advisories are authoritative for U.S. defender prioritization; this advisory is marked final with initial release date 2026-06-11
CISA CSAF JSON for ICSA-26-162-02	Machine-readable vulnerability, CVSS, product, and remediation records	High	Useful for traceability and automation; matches advisory content
CISA ICS recommended practices	Defense-in-depth guidance for control-system and remote-device exposure reduction	High	General mitigations; not a Naxclow-specific patch
Public secondary indexing observed in search results	Confirms broad mirroring of the CISA advisory	Medium	Secondary sources add little unique technical value; use CISA as source of truth

Admiralty code: A1. The source is reliable and the information is confirmed through CISA's published advisory/CSAF record. Confidence is lower only for campaign-level exploitation because no independent incident reporting or exploit telemetry was available in the reviewed public source set.

Key source limitations:

- No vendor fix, firmware version, or cloud-platform remediation was identified in the CISA advisory.
- The advisory does not provide endpoint paths, protocol fields, proof-of-concept exploit code, or exact platform hostnames.
- Detection logic must therefore emphasize exposure management, identity/state anomalies, network egress, and device behavior rather than byte-accurate exploit signatures.

4. Key Findings

Finding	Assessment	Defensive Implication
The vulnerability set affects all listed	CISA lists Smart Doorbell X3, X Smart	Inventory must search by product family,

versions of four Naxclow product lines	Home, V720, and ix cam as `vers:all/*`	mobile app/cloud platform linkage, procurement records, and physical device labels, not just by a fixed firmware range
Platform request signing is structurally weak	CVE-2026-28742 describes a hard-coded platform-wide salt and lack of per-device keys, nonce tracking, or replay protection	Compromise of one firmware image can create platform-wide request-forgery risk
Device ownership and relay authorization controls are insufficient	CVE-2026-42947 and CVE-2026-50108 enable device reassignment and relay credential access under the described conditions	Attackers may take over devices, intercept communications, or disrupt device relay channels
Device identity is enumerable	CVE-2026-42932 and CVE-2026-50244 expose predictable identifiers and registration high-water marks	Attackers can discover fleet scale and target active device ranges without broad scanning
Relay credentials are persistent and non-rotating	CVE-2026-50101 describes credentials that remain valid indefinitely and cannot be reset or revoked by the legitimate owner	Factory reset or re-onboarding may not remove an attacker who already obtained relay credentials
Physical debug exposure leaks WiFi secrets	CVE-2026-50099 exposes SSID, PSK, negotiated WPA keys, and an RT-Thread shell through labeled UART pads	Devices mounted in accessible locations can become a path to network credential theft and firmware extraction
No public exploitation was reported to CISA at release time	CISA states no known public exploitation specifically targeting the vulnerabilities	Absence of known exploitation should not delay containment because the weaknesses are high-impact and several are remotely reachable

Vulnerability summary:

CVE	CWE / Weakness	CVSS v3.1	Attack Preconditions	Security Impact
CVE-2026-42947	CWE-639 Authorization Bypass Through User-Controlled Key	8.8 High	Attacker has any account and can replay confirm-then-bind sequence	Silent device reassignment/takeover
CVE-2026-50108	CWE-862 Missing Authorization	7.5 High	Attacker can present a platform-valid request signature	Retrieval of relay credentials for arbitrary devices
CVE-2026-50101	CWE-262 Not Using Password Aging	8.1 High	Attacker obtains persistent relay credential through any exposure path	Long-term relay impersonation/interception even after reset/re-onboarding
CVE-2026-28742	CWE-321 Use of Hard-coded Cryptographic Key	9.8 Critical	Attacker recovers platform-wide salt from any firmware image	Forged signed requests, impersonation, broad platform manipulation
CVE-2026-42932	CWE-340 Predictable Numbers or Identifiers	5.3 Medium	Network access to exposed platform behavior	Active fleet enumeration

CVE-2026-50244	CWE-862 Missing Authorization	5.3 Medium	Signed request with batch prefix and arbitrary account identifier	Sequential device-ID minting and high-water counter disclosure
CVE-2026-50099	CWE-538 Sensitive Information in Externally Accessible File/Directory	4.6 Medium	Brief physical access to production hardware UART	WiFi credential recovery and firmware extraction foothold

Affected product and exposure table:

Vendor	Affected Product / Line	Affected Versions	Deployment Context	Exposure Concern
Naxclow	Smart Doorbell X3	all versions	Internet-connected camera/doorbell device	Account/device binding, relay channel, physical access, local WiFi secrets
Naxclow	X Smart Home	all versions	Consumer/commercial smart-home integration	Platform-wide request signing and account/device authorization weakness
Naxclow	V720	all versions	Camera/mobile-app ecosystem	Relay credential exposure and fleet enumeration
Naxclow	ix cam	all versions	Camera/mobile-app ecosystem	Device takeover, communications interception, and local network credential exposure

5. Threat Context

The Naxclow issues matter because IoT devices often sit at the boundary between physical security, user privacy, and enterprise network trust. Doorbells and cameras are commonly deployed in locations where physical access is plausible, where the device can observe sensitive areas, and where the same WiFi network may support laptops, phones, printers, building systems, or small-office infrastructure. A cloud-connected camera ecosystem with weak platform identity controls can therefore create risk beyond the individual device.

The vulnerability cluster supports several realistic attacker paths:

Scenario	Plausible Path	Risk Notes
Remote account/device takeover	Attacker creates or uses an account, replays a confirm-then-bind workflow, and reassigns a target device	Could deny legitimate owner control while device remains online and apparently normal
Relay impersonation and interception	Attacker retrieves or reuses persistent relay credentials and registers as the target device	Enables communications interception/disruption where relay architecture is used
Platform-wide request forgery	Attacker extracts hard-coded signing salt from one firmware image and signs arbitrary requests	Highest strategic risk because a single recovered secret may generalize across products

Fleet enumeration	Attacker abuses predictable identifiers and high-water mark disclosure to map active devices	Enables targeted follow-on operations against a known device population
Physical-to-network credential theft	Attacker accesses labeled UART on an outdoor or shared-space device and captures WiFi credentials	Especially relevant for doorbells/cameras installed outside secured office areas

Sector relevance is not limited to CISA's listed Commercial Facilities sector. Lost Boys Cyber flags additional relevance for defense contractors, manufacturers, small offices, executive residences, warehouses, and facilities that use consumer-grade cameras or doorbells as convenience security controls. The devices may not be part of a formal OT system, but the credential and monitoring implications can still affect corporate risk.

MITRE ATT&CK mapping is conservative because the advisory does not describe a named threat actor or observed campaign. The mapping below reflects plausible behaviors enabled by the vulnerability class and should be used for detection/hunt planning, not attribution.

Technique	Name	Evidence / Rationale
T1190	Exploit Public-Facing Application	Platform/API flaws can be abused through exposed cloud/API workflows where attackers interact with service endpoints
T1557	Adversary-in-the-Middle	Relay impersonation and communications interception are explicit CISA-described outcomes
T1078	Valid Accounts	Attack path may involve any attacker-controlled account and abuse of account/device binding semantics
T1040	Network Sniffing	UART exposure of WiFi material and relay interception can support credential or traffic capture
T1552	Unsecured Credentials	Persistent relay credentials and WiFi PSK/key exposure are credential-protection failures
T1595	Active Scanning	Predictable identifiers and high-water mark behavior support enumeration of active device ranges
T1608	Stage Capabilities	Forged platform requests or device impersonation can support preparation of follow-on access paths

6. Detection and Hunting

Detection should be designed around three realities: the advisory provides no exploit payload signature, several issues are cloud/API-side and may not be visible from enterprise endpoints, and affected devices may be unmanaged IoT assets without EDR. The most effective controls are exposure discovery, network segmentation validation, credential-rotation evidence, and anomaly detection around device/cloud communication patterns.

Detection Goal	Telemetry Source	Analytic Value	Confidence
Identify Naxclow devices or mobile-app ecosystems	DHCP, DNS, firewall, wireless controller, asset inventory,	Establishes exposure population	Medium-High

	procurement records		
Detect unusual Naxclow cloud/API communication	DNS/proxy/firewall logs	Surfaces unexpected relay/API activity or devices outside approved segments	Medium
Find IoT devices on sensitive networks	NAC, DHCP, EDR network telemetry, switch/wireless controller data	Identifies segmentation failures	High
Hunt possible fleet enumeration or scripted API abuse	Proxy/API gateway logs where available	Detects high-rate sequential requests or repeated device/account binding attempts	Medium
Identify physical-compromise follow-up	Wireless logs, credential rotation records, suspicious new devices on SSIDs used by Naxclow hardware	Useful after suspected UART access or device tampering	Medium

KQL exposure hunt for Microsoft Defender XDR environments collecting network telemetry:

```
// Identify endpoints communicating with Naxclow/V720/ixcam-related services or devices that should be reviewed.
// Tune RemoteUrl/domain terms after local DNS baselining; vendor cloud hostnames may vary by region/app generation.
let Lookback = 30d;
let NaxclowTerms = dynamic(["naxclow", "v720", "ixcam", "ix cam", "xsmart", "smartdoorbell", "smart-doorbell"]);
DeviceNetworkEvents
| where Timestamp > ago(Lookback)
| where RemoteUrl has_any (NaxclowTerms) or InitiatingProcessCommandLine has_any (NaxclowTerms)
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Connections=count(), RemoteUrls=make_set(RemoteUrl, 25), RemoteIPs=make_set(RemoteIP, 25) by DeviceName, InitiatingProcessFileName, InitiatingProcessAccountName
| order by Connections desc
```

KQL hunt for IoT devices communicating from sensitive VLANs or user networks:

```
// Review non-managed or IoT-like devices communicating from sensitive networks.
// Replace SensitiveSubnets with locally defined ranges and enrich with DHCP/NAC inventory where available.
let SensitiveSubnets = dynamic(["10.10.0.0/16", "10.20.0.0/16", "192.168.50.0/24"]);
DeviceNetworkEvents
| where Timestamp > ago(14d)
| where isnotempty(LocalIP) and RemoteIPType == "Public"
| extend InSensitiveRange = ipv4_is_in_any_range(LocalIP, SensitiveSubnets)
| where InSensitiveRange
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Connections=count(), RemotePorts=make_set(RemotePort, 20), RemoteUrls=make_set(RemoteUrl, 20) by DeviceName, LocalIP, InitiatingProcessFileName
| where DeviceName has_any ("camera", "doorbell", "iot", "unknown") or InitiatingProcessFileName in~ ("", "unknown") or Connections > 100
| order by Connections desc
```

Proxy/SIEM query pattern for possible enumeration or abnormal device binding attempts:

```
index=proxy OR index=firewall earliest=-30d
(uri_path="*bind*" OR uri_path="*register*" OR uri_path="*relay*" OR uri_path="*device*" OR url="*v720*" OR url="*naxclow*" OR url="*ixcam*")
| stats count min(_time) as first_seen max(_time) as last_seen dc(uri_query) as unique_queries values(uri_path) as paths values(src_ip) as src_ips by user, dest_host
| where count > 50 OR unique_queries > 25
| convert ctime(first_seen) ctime(last_seen)
| sort - count
```


Sigma-style network anomaly detection for Naxclow-related API abuse:

```

title: Possible Naxclow IoT Platform Enumeration Or Device Binding Abuse
id: 2f6c9d28-b187-4d5f-9087-naxclow-iot-api-abuse
status: experimental
description: Detects high-volume proxy or web-gateway requests containing Naxclow/V720/ixcam terms and
device registration, binding, or relay keywords. This is not an exploit signature; it is a hunt
analytic for activity consistent with the CISA-described vulnerability cluster.
author: Lost Boys Cyber
date: 2026-06-16
references:
- https://www.cisa.gov/news-events/ics-advisories/icsa-26-162-02
logsource:
  category: proxy
  product: generic
detection:
  vendor_terms:
    url|contains:
      - 'naxclow'
      - 'v720'
      - 'ixcam'
      - 'ix cam'
  operation_terms:
    url|contains:
      - 'bind'
      - 'register'
      - 'relay'
      - 'device'
  condition: vendor_terms and operation_terms
fields:
- src_ip
- user
- url
- http_method
- http_status
falsepositives:
- Legitimate device onboarding, mobile app setup, vendor diagnostics, or inventory scans.
level: medium

```

Threat-hunting hypotheses:

Hypothesis	Hunt Method	Expected Confirmation
Naxclow devices exist on networks where they were never approved	Correlate DHCP, wireless, firewall, procurement, and facility-security inventory	Unknown IoT devices, V720/ixcam app traffic, or camera/doorbell hostnames appear on sensitive VLANs
An attacker is enumerating device identifiers or registration state	Review proxy/firewall/API logs for repeated register/bind/device/relay requests and sequential identifiers	High request counts, many unique query strings, or source clustering against vendor endpoints
A device was physically accessed and WiFi credentials may be exposed	Compare device location, tamper reports, wireless reauthentication, and new-client joins after access window	New or suspicious clients appear on the same SSID after device tampering or maintenance
Persistent relay credentials are being abused	Monitor simultaneous or geographically inconsistent relay sessions if vendor/app telemetry is available	Multiple relay registrations for one device, odd source ASN/region, or owner-reported stream/control anomalies

7. Recommendations

Priority	Owner	Action	Target Timeline	Evidence of
----------	-------	--------	-----------------	-------------

				Completion
Critical	Asset / Facilities / Physical Security	Inventory all Naxclow Smart Doorbell X3, X Smart Home, V720, and ix cam deployments, including executive residences and small offices connected to corporate networks	24-72 hours	Asset list with owner, network segment, physical location, and product line
Critical	Network Engineering	Remove affected devices from sensitive networks; place remaining devices on isolated IoT VLANs with egress restricted to explicitly required destinations	24-72 hours	Firewall/NAC policy, VLAN assignment, and deny-by-default egress rule evidence
High	IT / Wireless Engineering	Rotate WiFi credentials for networks where affected devices are deployed in physically accessible locations or where tampering cannot be ruled out	7 days	Credential rotation/change ticket and forced client reauthentication logs
High	Security Operations	Deploy the exposure and anomaly hunts in this report; tune domain/URL terms after DNS and proxy baselining	7 days	Saved SIEM/EDR queries, reviewed results, and documented false positives
High	Procurement / Risk Owners	Request vendor remediation details, firmware/platform fix status, and credential-rotation capability; plan replacement if no fix is available	14 days	Vendor response, risk exception, replacement plan, or decommission ticket
Medium	Incident Response	Prepare playbook steps for suspected Naxclow compromise: isolate device, preserve network logs, rotate WiFi, review account/device binding, and notify affected users	14 days	Approved playbook and tabletop notes
Medium	Vulnerability Management	Track CVEs CVE-2026-42947, CVE-2026-50108, CVE-2026-50101, CVE-2026-28742, CVE-2026-42932, CVE-2026-50244, and CVE-2026-50099 in	14 days	Ticketed CVEs with owners, due dates, and compensating controls

		exception/remediation tooling		
--	--	-------------------------------	--	--

Compensating controls while the vendor remediation status is unresolved:

- Treat affected devices as untrusted IoT assets and prevent lateral access to user, server, OT, security-camera-management, and administrative networks.
- Disable or remove devices from sites where privacy, defense, manufacturing, or executive risk is unacceptable.
- Do not rely on factory reset or re-onboarding as a complete recovery action because CVE-2026-50101 describes non-rotating relay credentials.
- Review mobile app/account access for unauthorized device bindings or unexpected shared users.
- Establish a tamper-response process for outdoor/physically accessible devices, including WiFi credential rotation and local network review.

8. References

- [1] CISA, "Naxclow IoT Platform," ICSA-26-162-02, published 2026-06-11. <https://www.cisa.gov/news-events/ics-advisories/icsa-26-162-02>
- [2] CISA CSAF machine-readable advisory for ICSA-26-162-02. https://github.com/cisagov/CSAF/blob/develop/csaf_files/OT/white/2026/icsa-26-162-02.json
- [3] CISA, "Recommended Practices" for industrial control systems, linked from the Naxclow advisory. <https://www.cisa.gov/ics>
- [4] CISA, "Improving Industrial Control Systems Cybersecurity with Defense-in-Depth Strategies," referenced by CISA ICS recommended practices. <https://www.cisa.gov/resources-tools/resources/improving-industrial-control-systems-cybersecurity-defense-depth-strategies>
- [5] CISA, "ICS-TIP-12-146-01B--Targeted Cyber Intrusion Detection and Mitigation Strategies," referenced by CISA ICS recommended practices. <https://www.cisa.gov/news-events/ics-alerts/ics-alert-12-146-01b>